

Untrusted input boundaries

Project: Grounded Learning Service

1. Your mission

Your learning target

I can explain the mechanism and terminology of untrusted input boundaries.

I can apply the stated procedure to a new case with a traceable result.

I can identify an assumption or limitation and design a revealing follow-up.

Remember before reading

Close your notes first. A rough first answer helps us choose the right starting point; it is not a score for your ability.

Without opening the old lesson, explain one key idea from External side effects and recovery. Give an example and a mistake that the idea helps you avoid.

Without opening the old lesson, explain one key idea from Approval gates and idempotency. Give an example and a mistake that the idea helps you avoid.

Without opening the old lesson, explain one key idea from Logs traces and privacy. Give an example and a mistake that the idea helps you avoid.

After trying, check the relevant lesson or ask your teacher. Change the part of your explanation that the evidence shows was wrong.

This week you will practise:

Explain the mechanism and terminology of untrusted input boundaries

Apply the stated procedure to a new case with a traceable result

Identify an assumption or limitation and design a revealing follow-up

Retrieve what you already know

Recall External side effects and recovery. Explain why a recorded result needs its input conditions and evidence source before it can support a claim.

My starting explanation

This week's end goal

Explain untrusted input boundaries using the deciding step in this fictional service.

2. Notice the evidence

Untrusted input must be treated according to a contract before reaching code, queries or tools. Data that resembles instructions does not acquire execution authority.

Begin by writing the question the procedure is intended to answer. Identify the information already supplied, the information it will produce and the information still missing. These are constructed classroom examples; they do not require live accounts, private records or an external service. Do not treat a plausible explanation as a measured outcome.

List the given facts and one fact that is not supplied.

3. See how it works

For the toy lookup accept room IDs matching one uppercase letter plus one digit. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.

Untrusted input boundaries — evidence trace

Input and scope · Check or calculation · Conclusion and limit

Input and scope: Inputs A1 and delete_all() are supplied to room lookup.

Check or calculation: For the toy lookup accept room IDs matching one uppercase letter plus one digit. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.

Conclusion and limit: A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for

qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Before applying the procedure, write its units, denominator or decision boundary where relevant. A partner should be able to repeat each step using the same inputs. If a required input is absent or violates the stated contract, record that condition explicitly instead of quietly replacing it with a convenient value.

Connect the picture and the explanation

Point to the input, the deciding step and the result in this week's visual. Explain the same step in ordinary words. A picture helps when you can say what each part represents.

4. Compare the cases

Compare a familiar case with a changed case

Inputs A1 and delete_all() are supplied to room lookup. Show the intermediate steps and give the conclusion with its scope.

Keep the procedure fixed. Explain what changed in the inputs and result.

Change one thing in the pictured case

Change: Replace h3 with z0.

Prediction: The shape passes; resource access is still undecided.

Reason: Structure contains no evidence of ownership or user permission.

5. Words that unlock the idea

Word · Meaning

Word: Untrusted input

Meaning: Data whose claims or control intent have not been authorised

Word: Full match

Meaning: Validation covering the whole input

Word: Injection boundary

Meaning: A separation preventing data from becoming executable control

Use two terms to explain a step in this week's example.

6. Follow a worked example

Inputs A1 and delete_all() are supplied to room lookup.

A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

Compare the intermediate evidence with the final statement. Explain why each number or decision follows from the stated inputs. The conclusion belongs to this scenario and procedure; changing the inputs, evaluation population or authority can change what it establishes. Retain the raw record so a later revision can be compared honestly.

Optional local lab: predict the printed result before running this standalone Python 3 example. Change one relevant boundary input, record the outcome and state the contract or statistical assumptions. The program uses fictional values and the Python standard library; it performs no external operations.

```
import re

def validate_identifier(value):
    return type(value) is str and re.fullmatch('[A-Z][0-9]', value) is not
    None

print(validate_identifier("B2"))
```

Learn from the worked case

Cover the result before checking it. Say what is given, choose the procedure, and follow one step at a time. Then uncover the result and explain your first mismatch. Ask why a step is allowed, not only what number it produces.

A pictorial worked case: Untrusted input boundaries

Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one digit, with no trimming.

The facts we will use

Inputs h3, H3, h30 and "h3 ". Shape acceptance never grants access by itself.

AI ACADEMY / AI-6/18

Untrusted input boundaries

Start with the supplied facts

Follow each arrow. Ask which fact allows the next step.



1. Validate h3

Two characters with the required case and digit pass.



2. Reject wrong shapes

H3 has wrong case; h30 and the trailing-space input have wrong length.



3. Check authority next

An accepted identifier still needs trusted authorisation.

CHANGE ONE THING

Replace h3 with z0.

Explain the changed result using the matching lesson.

Read the picture one step at a time

Step · What happens and why

Step: 1. Validate h3

What happens and why: Two characters with the required case and digit pass.

Step: 2. Reject wrong shapes

What happens and why: H3 has wrong case; h30 and the trailing-space input have wrong length.

Step: 3. Check authority next

What happens and why: An accepted identifier still needs trusted authorisation.

Match each pictured step to the supplied facts. This is a worked teaching case, not an independent assessment.

Why this result follows

Input shape and permission answer different questions. Silently normalising these inputs would change the stated contract.

What this example does not establish

Some systems normalise inputs explicitly; this fictional contract deliberately does not.

Read the labelled picture: Classify h3, H3, h30 and the trailing-space input by the stated shape contract. Does a valid z0 grant record access, and which separate gate still remains?

Change one thing: Replace h3 with z0. Predict the result before checking the explanation. What remains the same?

7. Find and repair a mistake

A format check does not grant resource access; authorisation follows separately.

A useful check asks what would make the reasoning fail. Distinguish a failure to execute the declared procedure from a weakness in the procedure itself. The first may require a correction; the second requires an explicitly revised method and new evidence. Preserve unsuccessful cases so an improved result cannot hide the original problem.

Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.

Locate the earliest unsupported step

A report omits this qualification: A format check does not grant resource access; authorisation follows separately. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

State one repair and the checks you would rerun.

8. Practise together

Explain the weekly mechanism in your own words. Use the worked scenario to name its input, decision rule and output.

Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.

Explain your prediction to a partner before comparing results.

Practise with less help: Trace the worked case

Use workbook W2 for the connected example “Untrusted input boundaries”. First fill the input and rule boxes. Try the middle steps before asking for a hint. After a hint, try the next step yourself.

Plan · Do · Check

Plan: What is given? Which rule or procedure applies?

Do: Record each intermediate step.

Check: Does the result follow? What remains unknown?

Explain your trace to a partner. Your partner points to one step to check. Swap roles on the next case. Each person writes their own explanation.

Check your reasoning

Use the worked case for Untrusted input boundaries. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported. Point to the step or supplied fact that decides; explain your repair if needed.

Answer on your own before discussion. If you are unsure, say which step you need help with.

Explain the picture

Classify h3, H3, h30 and the trailing-space input by the stated shape contract. Does a valid z0 grant record access, and which separate gate still remains?

My explanation using a pictured step and the given facts

This is supported practice. Keep the separately named independent case for an attempt before feedback.

9. Run the investigation

Predict, investigate and preserve the evidence

Inputs A1 and delete_all() are supplied to room lookup. Show the intermediate steps and give the conclusion with its scope.

```
import re

def validate_identifier(value):
    return type(value) is str and re.fullmatch('[A-Z][0-9]', value) is not
None

print(validate_identifier("B2"))
```

Record · Your evidence

Record: Given input and fixed rule

Your evidence: _____

Record: Prediction before checking

Your evidence: _____

Record: Actual result, or “not run”

Your evidence: _____

Record: First mismatch and one explanation

Your evidence: _____

Record: Boundary or missing input and expected response

Your evidence: _____

On paper, trace the supplied procedure. If code is provided, predict before running it in a local practice file. Never write an expected answer as though it were an observed run.

Plan → try → check

Before trying: what do I expect, and why? While trying: which step could first go wrong? Afterwards: what did I actually observe, and what should change? Keep “not run” if you only traced the procedure.

10. Build your understanding

Explain → apply → challenge

Explain the weekly mechanism in your own words. Use the worked scenario to name its input, decision rule and output.

A report omits this qualification: A format check does not grant resource access; authorisation follows separately. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison. Do not reuse W4 as a new final test after receiving feedback.

Explain which evidence supports your conclusion and which claim remains unproved.

11. Connect your project

Add a labelled untrusted input boundaries evidence sheet to Grounded Learning Service. Show how you can explain the mechanism and terminology of untrusted input boundaries. Use the supplied fictional case and keep its inputs, intermediate steps, calculation or prediction, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

Project evidence · Record

Project evidence: Component and version

Record: _____

Project evidence: Inputs permitted at prediction time

Record: _____

Project evidence: Trace and comparison with earlier work

Record: _____

Project evidence: Failure, limit and human review

Record: _____

Evidence for your project

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or evidence that makes the deciding step valid, so another team can review it.

12. Show what you know

Complete the supported workbook tasks before attempting W4 independently. Record any hints or help used. After feedback, use the teacher's fresh retry rather than copying the earlier answer. For a project, select a relevant new case, predict the outcome from the declared rule and preserve the result alongside any revision.

Exit: propose one revealing change to the worked scenario. State the expected outcome and the evidence that would make you revise your explanation.

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison. Do not reuse W4 as a new final test after receiving feedback.

My limited claim and a useful next check

13. Study a complete case

Complete evidence record

Untrusted input boundaries — evidence trace

Input and scope · Check or calculation · Conclusion and limit

Input and scope: Inputs A1 and delete_all() are supplied to room lookup.

Check or calculation: For the toy lookup accept room IDs matching one uppercase letter plus one digit. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.

Conclusion and limit: A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Follow the input through the stated procedure to its result. Cover the result first, predict it, then explain every intermediate step. The text/table accompanies the figure so the example can be read without colour.

My complete trace of the worked case

14. Try a new case independently

Independent case: Changed independent case

Input format is exactly one ASCII uppercase letter followed by one digit, with no trimming. Evaluate C0, c0, C00, "C0 ", and None. Does a valid format grant access?

My independent explanation, trace and limits

Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

Attempt this without hints

Classify B2, b2, B22 and B2; DROP under the exact format.

My independent procedure, result and limitation

Record support used: none, hint or teacher explanation. After feedback, a different case is needed to demonstrate independence.

Use feedback to improve

Attempt the independent case before hints. Record whether you worked alone, used a hint or followed a model. After feedback, fix the first unsupported step and explain why it changed. A later check uses a changed case, not a copied answer.

15. Your lesson route

Start with this question: Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one digit, with no trimming.

By the end, I can · How I will show it

By the end, I can: Explain the mechanism and terminology of untrusted input boundaries

How I will show it: Explain the deciding step, show a trace or test, and state one limit.

By the end, I can: Apply the stated procedure to a new case with a traceable result

How I will show it: Explain the deciding step, show a trace or test, and state one limit.

By the end, I can: Identify an assumption or limitation and design a revealing follow-up

How I will show it: Explain the deciding step, show a trace or test, and state one limit.

Remember → watch and explain → try with help → investigate → try independently → keep project evidence. Your teacher may spread this lesson across several classes.

Keep your first prediction. Compare it with what the evidence shows and explain any change.

16. Finish and return

Close your notes. Explain this goal in your own words: Explain the mechanism and terminology of untrusted input boundaries

My deciding step, evidence and one remaining question

If you are unsure, return to the worked picture and explain one arrow. If you are ready, change an input or assumption and justify your prediction.

Save your workbook evidence. At the next review, try a different case before opening your old answer.

17. Supported practice, repair and portfolio

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one digit, with no trimming.

Practice 1: explain the deciding evidence

Which labelled step matches this detail? An accepted identifier still needs trusted authorisation.

1. Reject wrong shapes
2. Check authority next
3. Validate h3

My selected conclusion, deciding fact and explanation

Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

After your attempt, compare with the supported explanation: Check authority next An accepted identifier still needs trusted authorisation. Input shape and permission answer different questions. Silently normalising these inputs would change the stated contract.

Practice 2: explain the deciding evidence

Changed-case practice: Replace h3 with z0. Which conclusion is supported by the supplied facts?

1. We can decide the result without examining the changed input or the procedure.
2. The shape passes; resource access is still undecided.
3. This one example guarantees correct results for every future input.

My selected conclusion, deciding fact and explanation

Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

After your attempt, compare with the supported explanation: The shape passes; resource access is still undecided. Structure contains no evidence of ownership or user permission.

Repair a missing building block

Review External side effects and recovery (ai-6/17). Goal: Explain the mechanism and terminology of external side effects and recovery. Short practice: Distinguish a missing printer acknowledgement from confirmed failure. What should happen if J6 is complete, and what evidence changes when J6 is reliably reported absent?. Return to this week and explain what you changed.

Review Approval gates and idempotency (ai-6/15). Goal: Explain the mechanism and terminology of approval gates and idempotency. Short practice: Trace the two deliveries of approved K9. How many reservations should occur, and why can a new K10 for desk 5 not borrow K9's approval?. Return to this week and explain what you changed.

Review Logs traces and privacy (ai-6/12). Goal: Explain the mechanism and terminology of logs traces and privacy. Short practice: Identify the purpose of R17, C8 and 240 ms in the trace. Which field is deliberately omitted, and why would logging the whole question violate this design?. Return to this week and explain what you changed.

Predict, run and debug

The browser lab lets you edit the supported Python examples already included in this lesson. Predict first, run, inspect the actual output or error, change one input, then run again. Keep code, predictions, actual results and a reasoned revision together. On paper, label your result as a trace rather than an execution.

Keep your completed work

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run evidence. Open the HTML copy to read or print it. Drafts stay in this browser when storage is available; clear drafts on a shared device.